

Alunos: Gabriel Vitório Gonçalves, Lucas Leal de Oliveira e Yuri Cidral

Stack Tecnológica

Linguagens de Programação:

- Node/js + JavaScript
TypeScript
- Iremos utilizar essas linguagens pois já temos um conhecimento prévio além de que queremos nos aprofundar mais

Frameworks e Bibliotecas:

- React: A utilização desse framework será para aprendizado, pois ainda não temos conhecimento nela, mas temos curiosidade

Ferramentas de Desenvolvimento e Gestão:

- Postman
- Docker
- Supabase
- Visual Code
- Jira
- Github
- Github actions

Licenciamento:

- Node/js + JavaScript – MIT license
- TypeScript – apache license 2.0
- Postman – comercial/ plano gratuito
- Docker – apache license2.0
- Supabase – parte opersource(apache license 2.0) / plano gratuito
- Visual Code – MIT license
- Jira – comercial/ plano gratuito
- Github/actions– plano gratuito

Considerações de Segurança

Riscos Identificados:

- Vazamentos de dados entre lojas

- Vazamento de dados sensíveis
- Falhas de autenticação
- Controle de acesso inadequado
- Injeção de código
- Configuração incorreta de permissão no banco
- Exposição de segredos
- Dependências vulneráveis
- Ataques de negação de serviço (DoS / DDoS)
- Perda de dados por falha de backup
- Engenharia social e phishing contra usuários administradores

Medidas de Mitigação: Explique as ações planejadas para minimizar riscos (ex.: criptografia, controle de acesso, validação de entrada).

Autenticação e Controle de Acesso

- Tokens JWT com tempo de expiração curto.
- MFA (autenticação multifator) para administradores.
- Rate limit em rotas sensíveis (login, reset de senha).
- Política de senha forte.

Proteção contra Ataques Comuns

- Validação rigorosa de entrada
- prevenção contra SQL Injection
- Escape automático de conteúdo no frontend
- Uso de headers de segurança.
- Proteção CSRF quando aplicável.
- Limitação de upload de arquivos

Proteção de Dados

- HTTPS obrigatório
- Criptografia em repouso
- Armazenamento seguro de segredos
- Não armazenar senhas em texto plano
- Minimização de coleta de dados
- Mascaramento de dados sensíveis em logs.

Backup e Continuidade

- Backup automático diário do banco.
- Testes periódicos de restauração.

- Armazenamento de backup com acesso restrito.

Monitoramento e Auditoria

- Logs de acesso e ações críticas.
- Auditoria de alterações administrativas.
- Monitoramento de tentativas de login suspeitas.
- Alertas para comportamento anômalo.
- Scan automático de vulnerabilidades nas dependências.

3. Normas e Boas Práticas Seguidas

O projeto seguirá padrões reconhecidos internacionalmente:

- OWASP Top 10 (prevenção contra as vulnerabilidades mais críticas).
- ISO/IEC 27001 (boas práticas de gestão de segurança da informação).
- LGPD para tratamento de dados pessoais.
- Princípio do Menor Privilégio.
- Defesa em Camadas
- Secure by Design e Privacy by Design.

4. Responsabilidade Ética

Como o sistema manipula dados de clientes e lojistas:

- Garantia de privacidade e confidencialidade.
- Transparência no uso de dados.
- Coleta apenas de dados estritamente necessários.
- Direito do usuário de solicitar exclusão ou exportação dos dados.
- Não utilização de dados para fins não autorizados.
- Tratamento justo e não discriminatório de informações.
- Caso haja uso de IA no futuro, seguir:
 - UNESCO – Ética em IA

- OECD AI Principles
- Garantia de ausência de vieses prejudiciais.